

DeFi Risk Management Guidance



TABLE OF CONTENTS

SECTION 1: INTRODUCTION	2
1.1 PURPOSE OF THE GUIDANCE.....	2
1.2 SCOPE AND APPLICABILITY	2
1.3 RELATIONSHIP WITH EXISTING FSRA REGULATORY FRAMEWORKS.....	3
1.4 KEY TERMS	4
SECTION 2: EFFECTIVE DEFI RISK MANAGEMENT.....	5
2.1 OVERVIEW	5
2.2 RISK MANAGEMENT PROGRAMME DESIGN AND CONTROL OBJECTIVES.....	6
2.3 GOVERNANCE AND SENIOR MANAGEMENT OVERSIGHT.....	8
2.4 DEFI ENGAGEMENT APPROVAL AND ONBOARDING	9
2.5 DUE DILIGENCE AND RISK ASSESSMENT.....	11
2.6 THIRD PARTY DEPENDENCIES AND CONCENTRATION AWARENESS.....	12
2.7 CONTINUOUS MONITORING AND DETECTION	13
2.8 RECORDKEEPING, AUDITABILITY AND MANAGEMENT INFORMATION.....	14
2.9 RESOURCING, COMPETENCE AND ACCOUNTABILITY	16
2.10 INCIDENT ESCALATION AND REGULATORY ENGAGEMENT.....	17
SECTION 3: DEFI INFRASTRUCTURE RISKS	18
3.1 OVERVIEW	18
3.2 CUSTODY, CONTROL AND ASSET ACCESS	19
3.3 PRIVACY, TRACEABILITY AND FINANCIAL CRIME CONSTRAINTS	21
3.4 SMART CONTRACT	23
3.5 PROTOCOL GOVERNANCE.....	25
3.6 ORACLE AND EXTERNAL DATA DEPENDENCY	26
3.7 BRIDGE AND INTEROPERABILITY.....	26
SECTION 4: DEFI EXPOSURE RISKS	34
4.1 OVERVIEW.....	34
4.2 FIAT-REFERENCED TOKEN EXPOSURES	35
4.3 SYNTHETIC ASSET AND DERIVATIVES-LIKE EXPOSURES	36
4.4 RECEIPT TOKEN AND TOKENISED CLAIM EXPOSURES	37
4.5 WRAPPED, BRIDGED AND CROSS-CHAIN ASSET EXPOSURES.....	38

SECTION 1: INTRODUCTION

1.1 PURPOSE OF THE GUIDANCE

- 1.1.1 This Guidance sets out the FSRA's expectations for how Authorised Persons and Recognised Bodies should identify, assess, monitor and control the risks that arise when they engage with decentralised finance ("DeFi") venues and protocols in connection with their Regulated Activities or Regulatory Functions. It is intended to support the safe, sound and orderly interaction of Authorised Persons and Recognised Bodies with DeFi, consistent with the FSRA's regulatory objectives.
- 1.1.2 The Guidance recognises that DeFi engagement introduces a set of risks that differ in pace, transmission, and control mechanisms from those inherent in traditional intermediation, including risks that may arise at the layer of cryptographic key management, smart contract behaviour, protocol governance, oracle dependency, bridge and interoperability arrangements, composability across protocols, execution environment, and mechanism design.
- 1.1.3 This Guidance does not create any new Financial Services Permission ("FSP"), authorisation or regulatory status, and does not approve, endorse or recognise any DeFi venue, protocol or provider. It does not apply to DeFi venues or protocols directly, and it does not change the Regulated Activities that may be carried on in or from ADGM. An Authorised Person or Recognised Body remains subject to the permissions, conditions and regulatory requirements applicable to it, including under any relevant Recognition Order, under the Financial Services and Markets Regulations 2015 ("FSMR") and the FSRA Rulebooks. The engagement of an Authorised Person or Recognised Body with DeFi neither extends, varies nor substitutes those permissions. This Guidance must not be read as permitting any DeFi venue, protocol or provider to establish itself or to carry on DeFi activity in or from ADGM.
- 1.1.4 Unless otherwise defined or the context otherwise requires, the terms contained in this Guidance have the same meaning as defined in FSMR, the FSRA Glossary Rulebook ("GLO"), and the relevant FSRA Rulebooks or guidance.
- 1.1.5 This Guidance is issued under section 15(2) of FSMR and should be read in conjunction with FSMR, the relevant Rulebooks of the FSRA, and the Guidance and Policies Manual.

1.2 SCOPE AND APPLICABILITY

- 1.2.1 This Guidance is applicable to the following Persons:
- an Authorised Person that engages with DeFi venues, protocols or providers in connection with carrying on a Regulated Activity, or whose carrying on of a Regulated Activity is otherwise materially affected by such engagement; and
 - a Recognised Body, being a Recognised Investment Exchange or Recognised Clearing House, whose activities, facilities, clearing or settlement arrangements, operating rules, systems and controls or other recognised functions involve or

depend on or are materially affected by engagement with DeFi venues, protocols or providers.

- 1.2.2 An Authorised Person or Recognised Body should treat this Guidance as relevant where its DeFi engagement is undertaken in connection with a Regulated Activity, or Regulatory Function that it is permitted to undertake, or where such engagement may materially affect the regulated entity's client asset arrangements, financial resources, systems and controls, governance, operational resilience, or overall risk profile.
- 1.2.3 For the purposes of this Guidance, references to an “Authorised Person” should be read as including a Recognised Body where the context permits and where the relevant expectation is proportionate to the nature, scale and complexity of the Recognised Body’s DeFi engagement. Where this Guidance applies to a Recognised Body, it does not modify, replace or detract from the Recognised Body’s obligations under the Market Infrastructure Rulebook (“MIR”) or its Recognition Requirements, and should be read in connection with them.
- 1.2.4 This Guidance focuses on the Authorised Person’s management and governance of its DeFi engagement, not the DeFi venues, protocols or providers with which it engages. It applies to the controls, recordkeeping, Client Asset safeguards and incident response arrangements through which an Authorised Person manages that engagement. It does not apply to, and does not impose, obligations on DeFi venues, protocols or providers. Whether a person or activity falls within the FSRA’s regulatory perimeter is determined under FSMR and the FSRA Rulebooks by reference to its substance and operation.
- 1.2.5 The regulatory outcomes expected of Authorised Persons for non-DeFi and DeFi activities is ultimately the same under the FSRA framework. The Guidance is structured to support an Authorised Person in managing those risks within its existing regulatory obligations, calibrated to the nature, scale and complexity of its DeFi engagement.

1.3 RELATIONSHIP WITH EXISTING FSRA REGULATORY FRAMEWORKS

- 1.3.1 This Guidance complements the FSRA’s existing regulatory framework for digital assets and related activities. This Guidance does not override, extend or restate the requirements those frameworks contain, and where any inconsistency may arise, the relevant Regulations and Rulebooks prevail. Authorised Persons should read this Guidance alongside, in particular:
 - a. FSMR, including the provisions concerning Regulated Activities, authorisation, the scope of an Authorised Person’s permissions and, where applicable, Market Abuse;
 - b. the General Rulebook (“GEN”), for the FSRA’s expectations on systems and controls, senior management responsibilities, governance arrangements, conflicts of interest, outsourcing, and notifications;
 - c. MIR and the applicable Recognition Requirements, where the regulated entity is a Recognised Body, in respect of its recognised functions, operating rules, clearing or settlement arrangements, and systems and controls;

- d. the Conduct of Business Rulebook ("COBS"), including Chapters 15 (Client Assets) and 16 (Client Money), 17 (Additional Rules - Virtual Asset Activities), and other applicable conduct provisions;
- e. the Anti-Money Laundering and Sanctions Rulebook ("AML"), and applicable Federal AML Legislation, for the FSRA's expectations on financial crime risk management, Targeted Financial Sanctions, and Sanctions screening;
- f. the Prudential - Investment, Insurance Intermediation and Banking Rulebook ("PRU") for the prudential treatment of relevant exposures;
- g. the Information Technology Risk Management Guidance ("ITRMG"), in particular Chapters 13 (Cryptography) and 15 (Decentralised Infrastructure Solutions);
- h. the FSRA's framework for Fiat-Referenced Tokens, and the Guidance - Regulation of Virtual Asset Activities in ADGM; and
- i. the FSRA's Guidance on Regulation of Digital Securities Activities in ADGM, and the Listing Authority framework where a DeFi exposure or structure involves, or gives rise to, a Digital Security or an offer of Securities that requires approval under that framework.

1.3.2 The Guidance has been developed in the light of consideration of DeFi by international standard-setting bodies including the work of International Organization of Securities Commissions (IOSCO), the Financial Stability Board (FSB), and the Financial Action Task Force (FATF).

1.4 KEY TERMS

1.4.1 The following terms are used in this Guidance with the meanings set out below. Where a term is defined elsewhere in FSMR, GLO or another FSRA Rulebook, that meaning applies. The descriptions below are intended to aid the reader of this Guidance and do not modify any definition in FSMR, GLO or the FSRA Rulebooks.

Term	Description
Automated market maker (AMM)	A smart-contract-based asset swapping arrangement in which prices are set by a deterministic pricing curve operating against asset reserves held in a pool, rather than by an order book.
Bridge	An arrangement that enables assets or messages to move between distinct blockchain networks, typically by locking an asset on one chain and issuing a representative token on another, or by relaying messages via validators or proof systems.
Composability	The property of DeFi protocols that allows a position in one protocol to be used as input to another, with the consequence that a DeFi engagement may depend on a chain of protocols rather than on a single protocol in isolation.

Term	Description
DeFi	Decentralised finance, meaning financial products, services or activities conducted through blockchain protocols or self-executing smart contracts. It is non-custodial, with participants interacting directly with smart contracts using their cryptographic keys, and assets committed to a smart contract are controlled by its code rather than a conventional intermediary. The degree of decentralisation may vary, where administrative keys, upgrade powers, emergency controls or identifiable persons exercising influence remain present.
DeFi engagement	The interaction of an Authorised Person, whether on its own behalf or on behalf of Clients, with DeFi venues, protocols or providers, in connection with a Regulated Activity
digital asset	In this Guidance, references to an 'asset' or 'digital asset' are to the digital assets an Authorised Person is permitted to use in DeFi engagement consistent with the FSRA framework, including Accepted Virtual Assets, Accepted Fiat-Referenced Tokens, Digital Securities, and other tokenised assets.
Know Your Transaction (KYT)	Screening of onchain transactions, counterparty addresses and execution paths against financial crime, sanctions and established illicit finance typologies.
Maximal extractable value (MEV)	The value that third parties able to influence transaction ordering may capture at the expense of other transacting parties, including through sandwich attacks, front-running, and order-flow extraction.
Onchain / Off-chain	"Onchain" refers to activity recorded on, or executed by, the underlying blockchain. "Off-chain" refers to activity that takes place outside the blockchain, including in conventional systems, databases, or counterparty arrangements.
Oracle	A service or arrangement that supplies external data, most commonly price data, into a smart contract or DeFi protocol.
Shielded transactions	Transactions that use cryptographic techniques or protocol arrangements to obfuscate the originating address, destination address, or transaction value, thereby impeding effective transaction monitoring and KYT screening.
Smart contract	Software deployed onchain that executes deterministically in accordance with its code when invoked under the conditions specified in the code.

SECTION 2: EFFECTIVE DEFI RISK MANAGEMENT

2.1 OVERVIEW

- 2.1.1 This Section sets out the risk management arrangements an Authorised Person should maintain for its existing or proposed DeFi engagement. The presence of these controls does not imply that any underlying activity, venue, protocol or exposure is approved or permitted by the FSRA, or that it falls within the regulatory perimeter.

- 2.1.2 The controls in this Section may be employed only where the engagement is itself permissible under the Authorised Person's permissions and the FSRA framework (see Section 1 and the engagement approval expectations at 2.4); due diligence and ongoing risk management controls do not make permissible an engagement the Authorised Person may not otherwise be able to undertake.
- 2.1.3 This Section should be read in conjunction with other applicable Regulations, Rules and Guidance, in particular GEN, MIR, COBS, AML, PRU, ITRMG and the Guidance for the Regulation of Virtual Asset Activities. Specific rule references are given inline where directly applicable. Where DeFi engagement gives rise to obligations under those frameworks, this Guidance does not duplicate, replace or expand those requirements.

2.2 RISK MANAGEMENT PROGRAMME DESIGN AND CONTROL OBJECTIVES

- 2.2.1 Effective DeFi engagement risk management is grounded in a programme that is designed, implemented and operated with the discipline the Authorised Person applies to risk management for its Regulated Activities. The programme should support identification, assessment, monitoring, control and communication of DeFi related risks across the Authorised Person's Regulated Activities. Specific technologies, venues and protocols will evolve. The control objectives set out below are intended to retain their relevance through that evolution.
- 2.2.2 An effective DeFi engagement risk management programme should be designed to achieve the following control objectives, calibrated to the nature, scale and complexity of the Authorised Person's DeFi engagement:
- a. clear accountability at the senior level: the Governing Body approves and oversees the Authorised Person's DeFi engagement strategy and risk appetite, supported by senior management's implementation of the approved framework and timely reporting on material engagements, exposures, controls, incidents and emerging risks;
 - b. structured engagement: each material DeFi engagement is approved through a defined process that tests, in sequence: (i) whether the engagement is permissible, being consistent with the Authorised Person's permissions and Regulated Activities; (ii) the proposed engagement against the Authorised Person's risk appetite, regulatory obligations and capability; and (iii) the suitability of the venue, protocol or provider;
 - c. layered and dynamic risk assessment: risks are identified and assessed at the level of the underlying activities, dependencies and exposures rather than as a single composite, and the assessment is updated as protocols, dependencies and external conditions change. The assessment considers the design and operating effectiveness of mitigating controls and the residual risk remaining after those controls are applied;
 - d. visibility of third party and concentration exposures: the Authorised Person knows where it has built dependencies on specific protocols, infrastructure providers,

custodians, oracles, bridges and other infrastructure or service arrangements, and how those dependencies aggregate;

- e. continuous monitoring and detection: monitoring arrangements give the Authorised Person timely visibility of changes in protocol behaviour, governance, dependencies, exposures, control breaches and external events that may affect its DeFi engagement;
 - f. auditability and management information: the Authorised Person maintains records that are sufficient for internal accountability, supervisory engagement and post-event reconstruction, including transaction records, counterparty and protocol identifiers, execution path metadata, and control breaches and their resolution;
 - g. adequate resources, competence and accountability: the Authorised Person has the people, technology, processes and budget needed to operate its DeFi engagement risk management arrangements, with clear individual accountability and arrangements that are not dependent on a single individual or on informal knowledge;
 - h. formalised arrangements to reduce, exit or isolate DeFi exposures: the Authorised Person maintains pre-defined and tested arrangements to reduce, exit or isolate DeFi exposures under stress where this remains technically possible. Testing may include tabletop exercises, simulations or other non-live testing where live execution would be unsafe or uneconomical; and
 - i. incident readiness and regulatory engagement: incident escalation, response and regulatory communication arrangements are defined in advance and exercised, recognising the speed at which DeFi incidents may unfold.
- 2.2.3 The Authorised Person should not solely rely on its ability to exit, hedge or reduce a DeFi exposure after a stress event as its main risk control. Exit routes that work in normal conditions may be unavailable, uneconomical or unsafe under stress. The Authorised Person's primary controls should therefore be applied before exposure is taken, and should include position sizing, exposure and concentration limits, protocol and provider selection, alternative execution or exit arrangements where feasible and the conditions under which further exposure will not be taken.
- 2.2.4 In assessing whether a DeFi engagement is material, an Authorised Person should consider relevant qualitative and quantitative factors, including the size and concentration of the exposure, potential impact on Clients or Client Assets, the criticality of underlying dependencies, operational complexity, financial crime and conduct risk, potential contagion across other exposures, and the speed and severity with which risk could crystallise.
- 2.2.5 These objectives are not exhaustive. They anchor the more detailed expectations set out in the remainder of this Section.

2.3 GOVERNANCE AND SENIOR MANAGEMENT OVERSIGHT

2.3.1 The Governing Body should:

- a. approve the Authorised Person's DeFi engagement strategy and risk appetite, including the activities, venues, protocols and providers within scope;
- b. maintain awareness of the Authorised Person's material DeFi engagements, exposures, dependencies, control breaches and incidents through regular management information, and provide effective oversight and challenge;
- c. oversee the integration of DeFi engagement into the Authorised Person's broader risk management, internal audit, conduct, financial crime, operational resilience and prudential arrangements; and
- d. understand and accept the key risks arising where the Authorised Person engages with a DeFi venue or protocol operating without a directly applicable regulatory framework.

2.3.2 Senior Management should:

- a. implement the DeFi engagement strategy and risk appetite approved by the Governing Body;
- b. establish and periodically review policies and standard operating procedures covering DeFi engagement approval, due diligence, monitoring, incident response, recordkeeping and escalation;
- c. ensure that responsibility for DeFi engagement risk management is allocated to identified individuals with the necessary seniority, technical understanding and independence, and that escalation paths are defined;
- d. ensure that each material risk identified in connection with the Authorised Person's DeFi engagement is adequately controlled or mitigated, and that any residual risk is understood, documented and accepted by a person with appropriate authority and within the Authorised Person's risk appetite;
- e. act in a timely manner on information relating to the Authorised Person's material DeFi engagements, exposures, dependencies, control breaches and incidents, and escalate material matters, whether they have occurred or may potentially do so, to the Governing Body;
- f. identify and manage potential or actual conflicts of interest arising from the Authorised Person's DeFi engagement, including through appropriate systems and controls, segregation of responsibilities or disclosure. Where a conflict cannot be adequately managed, the Authorised Person should not enter into, or should cease, the DeFi engagement; and
- g. where a product or service offered to Clients relies on DeFi engagement, ensure that disclosures to Clients clearly describe the nature, scope of the DeFi exposure, its

material risks and whether any DeFi venue or protocol on which the product or service materially relies operates without a directly applicable regulatory framework. The Authorised Person should review, and where necessary, update those disclosures when a material change to the DeFi engagement may affect their accuracy or completeness.

- 2.3.3 DeFi engagement does not require a separate governance structure. The Authorised Person's existing governance arrangements should be extended to cover DeFi engagement, with attention paid to the speed at which DeFi events crystallise and the technical competence required to interpret them.
- 2.3.4 DeFi engagement should be brought within the Authorised Person's existing risk management and control arrangements. Responsibility for operating DeFi controls, providing independent challenge, and obtaining appropriate periodic assurance over their design and effectiveness should be clearly allocated to suitably resourced functions and identified individuals, consistent with section 2.8.

2.4 DEFI ENGAGEMENT APPROVAL AND ONBOARDING

- 2.4.1 Each material DeFi engagement should be approved through a defined process before it commences and is onboarded with appropriate controls. The first step in that process is to establish whether the activities the Authorised Person proposes to undertake through the engagement are permissible under the FSRA framework and consistent with the Authorised Person's permissions and Regulated Activities. This assessment concerns the Authorised Person's activities and does not imply that the relevant DeFi protocol must itself be licensed or approved by the FSRA.
- 2.4.2 An engagement that the Authorised Person is not permitted to undertake must not proceed as it would be in breach of the Authorised Person's FSP, thereby potentially attracting enforcement action by the FSRA. Therefore, due diligence, risk mitigation or ongoing control etc cannot make such an engagement permissible. Only where a DeFi engagement is determined to be within the Authorised Person's FSP should the Authorised Person go on to establish whether the proposed engagement is within the Authorised Person's DeFi risk appetite, whether the Authorised Person has the capability to operate the engagement safely, and whether the proposed venue, protocol or provider has been subject to adequate due diligence (see 2.5).
- 2.4.3 Where a proposed DeFi engagement is novel to the Authorised Person, or where its regulatory implications are unclear, the Authorised Person should engage with the FSRA before commencing the engagement, and in any event before using Client Assets in connection with it.¹ Early engagement does not alter the permission and perimeter position, but allows any classification or perimeter question to be resolved before the DeFi engagement is undertaken.

¹ For the avoidance of doubt, a DeFi engagement does not alter the Client Asset requirements in any way. Client Assets must be kept in a Client Account maintained by a Third-Party Agent. The term Client Account means in relation to (a) Client Money and Relevant Money an account as described in COBS 14.6.1 and (b) a Safe Custody Asset an account as described in COBS 15.4.2.

2.4.4 The approval process should consider:

- a. the permissibility of the proposed engagement, as the threshold question that precedes all other considerations, including whether the engagement is consistent with the Authorised Person's regulatory permissions;
- b. the nature of the proposed exposure or interaction, the venue or protocol, and the connection to a Regulated Activity or to Client Asset arrangements;
- c. the legal and regulatory implications, including the legal status of the engagement, the legal nature of the digital assets, exposures or claims involved, and any prudential treatment that applies;
- d. the technical and operational requirements, including custody and wallet arrangements, signing and authorisation arrangements, transaction execution infrastructure, monitoring tooling, and incident response capability;
- e. third party dependencies, including custody, infrastructure, oracle, bridge, indexer and analytics providers, and any concentration that may arise from those dependencies (see 2.6);
- f. the resources, competence and accountability arrangements required to operate the engagement (see 2.9);
- g. the AML, sanctions, transaction traceability and wider financial crime risks associated with the proposed engagement, including whether the Authorised Person's business risk assessment requires updating in accordance with AML Rules 6.1.3 and 6.1.4 without limitation;
- h. the controls and mitigations proposed for each material risk identified, the residual risk remaining after those measures are applied, and whether that residual risk is within the Authorised Person's risk appetite; and
- i. the conditions under which the engagement would be paused, scaled back, or unwound.

2.4.5 Approval for the DeFi engagement should be granted at a level of seniority commensurate with the materiality of the DeFi engagement and should be documented. Onboarding should include the establishment of monitoring arrangements (see 2.7), the configuration of recordkeeping (see 2.8), and the rehearsal of escalation paths (see 2.10). Where the Authorised Person is using a new venue, protocol or provider for the first time, the Authorised Person should consider whether a graduated approach to exposure (for example with size or time limits) is appropriate during a defined familiarisation period.

2.4.6 Material change to an existing DeFi engagement, including changes in venue or protocol, material protocol upgrades, changes in custody arrangements, or changes in the risk profile of a provider or other material dependency, should be subject to re-approval.

2.5 DUE DILIGENCE AND RISK ASSESSMENT

- 2.5.1 Due diligence and risk assessment should underpin an Authorised Person's understanding of a DeFi engagement before the engagement commences and thereafter at intervals appropriate to the rate of change in the engagement and its environment.
- 2.5.2 Due diligence on the venue, protocol or provider should examine, at a level appropriate to the materiality of the engagement:
- a. protocol design and smart contract architecture;
 - b. the security history of the protocol, including the scope, timing, and limitations of relevant smart contract audits, identified vulnerabilities, incident history and remediation;
 - c. protocol governance arrangements, including the allocation and concentration of governance influence, the location of administrative and upgrade authority, the conditions under which that authority may be exercised, and any material control or intervention rights;
 - d. the existence, design, and operation of safety mechanisms, including pause functions, circuit breakers, redemption suspensions, oracle failover arrangements, and emergency upgrade mechanisms;
 - e. liquidity, market structure and concentration of holdings;
 - f. dependencies on oracles, bridges, indexers, sequencers and other infrastructure;
 - g. legal and regulatory considerations relevant to engagement, including the Authorised Person's applicable conduct and financial crime obligations, and any legal or regulatory uncertainty arising from the status, structure or operation of the relevant DeFi venue or protocol; and
 - h. operational considerations including documentation, support, communication channels, and the integrity of front-end interfaces.
- 2.5.3 Authorised Persons should recognise that they do not generally control protocol level safety mechanisms such as pause functions, circuit breakers, or upgrade authorities. Authorised Persons should assess the presence, design, governance and reliability of those mechanisms during initial due diligence, and consider how they would respond if a mechanism was triggered, failed, operated adversely to the Authorised Person's position, or was unavailable when needed.
- 2.5.4 Risk assessment should be conducted at a granular level. A single DeFi engagement often combines several underlying activities and exposures that may span multiple protocols, chains and venues. Authorised Persons should identify and assess each underlying activity and exposure and its associated risks, including the manner in which those risks may transmit across dependencies, rather than treating the engagement as a single composite exposure.

- 2.5.5 Stress testing and scenario analysis, as well as their frequency, should be calibrated to DeFi specific failure modes, including Fiat-Referenced Token depeg events, oracle manipulation or failure, exploit propagation along composability paths, sequencer or block proposer failure, bridge failure or partial loss, sudden liquidity withdrawal, governance attack or capture, and cascading liquidation. The output of stress testing should inform exposure sizing, hedging arrangements, and the conditions under which the Authorised Person would scale back or unwind the engagement.
- 2.5.6 Authorised Persons should assess potential or actual conflicts of interest arising from occupying multiple roles in relation to the same DeFi engagement, including as a governance token holder, voting participant, or liquidity provider to the venue. The assessment should consider how the Authorised Person's actions in one capacity could affect outcomes for Clients in another.

2.6 THIRD PARTY DEPENDENCIES AND CONCENTRATION AWARENESS

- 2.6.1 DeFi engagement creates dependencies beyond the venues or protocols with which the Authorised Person transacts. These typically include wallet infrastructure providers, signing and key management providers, blockchain data and analytics providers, oracle providers, bridge and interoperability protocols, indexer and node providers, transaction execution and routing services, and front-end infrastructure providers. Some of these dependencies are direct, where the Authorised Person has a contractual or operational relationship with an identifiable provider. Others are indirect, where the Authorised Person relies on infrastructure, services or chains on which the protocol or venue it uses itself relies.
- 2.6.2 The Authorised Person should maintain up-to-date understanding and records of its DeFi related third party provider dependencies, including the identity of those providers, the function(s) performed, the location of the provider's services, the Authorised Person's contractual rights, the provider's resilience and security arrangements, and the Authorised Person's ability to substitute the provider in the event of disruption or failure.
- 2.6.3 Concentration awareness should extend to dependencies that may be shared across multiple engagements or across the broader market. A single oracle provider, bridge protocol, sequencer, custodian or front-end service may underpin several of the Authorised Person's engagements at once and may also be relied on by other Authorised Persons. The Authorised Person should consider how its overall position would be affected by the failure of any such shared dependency, and whether mitigation, redundancy or graduated exposure arrangements are appropriate.
- 2.6.4 Where wallet or signing arrangements are outsourced, the Authorised Person should consider the operational resilience, security architecture, governance, financial soundness, incident response capability, recovery and migration support of the provider. Limited visibility into provider systems, weak auditability, unclear subcontracting, or inadequate recovery support may delay detection of failures and impede effective response. The Authorised Person retains full responsibility for ensuring compliance with all relevant requirements when engaging providers of outsourced services and should not assume that a provider's controls guarantee the integrity of its DeFi engagement.

Outsourcing arrangements remain subject to GEN Chapter 3 requirements, including GEN Rules 3.3.31 and 3.3.32, as well as the requirements under MIR Rule 2.14. Where the arrangement involves the provision of ICT Services, the relevant requirements include those concerning Third-Party Cyber Risk under GEN Rule 3.5.2.

2.7 CONTINUOUS MONITORING AND DETECTION

- 2.7.1 Monitoring arrangements should give the Authorised Person timely visibility of the activity, exposure, dependencies, governance and external context of its DeFi engagement, and should be capable of triggering management attention when thresholds are breached or anomalous behaviour is detected.
- 2.7.2 The frequency, depth and form of monitoring, reassessment, testing and escalation should be commensurate with the nature, scale and complexity of the Authorised Person's DeFi engagement, the materiality of the exposure or dependency, and the speed and severity with which the relevant risk could crystallise. Where this Guidance refers to continuous monitoring or timely escalation, the FSRA expects arrangements that are capable of identifying and responding to material risk events within a timeframe appropriate to the engagement, rather than undifferentiated review of every protocol, dependency or data point at all times.
- 2.7.3 Continuous monitoring should cover, as relevant to the engagement:
- a. the Authorised Person's transactional activity and exposure, including position size, collateral, leverage, liquidity and concentration;
 - b. the operational health of the venues, protocols and dependencies used, including the observable status of automated safety mechanisms such as pause functions, circuit breakers, redemption arrangements, oracle feeds and failover arrangements;
 - c. governance activity and changes affecting the venues or protocols used, including proposal flows, voting outcomes, changes in administrative or upgrade authority, and use of emergency powers;
 - d. external indicators of stress relevant to the engagement, including Fiat-Referenced Token peg behaviour, depeg risk indicators, large outflows, abnormal trading patterns, governance disputes elsewhere in the ecosystem, and incidents affecting shared dependencies;
 - e. financial crime indicators, including transaction patterns, counterparty exposure, sanctions exposure, and indicators arising from blockchain analytics and screening tools;
 - f. the integrity of the Authorised Person's own systems and interfaces, including signing arrangements, access controls, automated execution tooling, dashboards, and monitoring outputs themselves; and
 - g. the continuing adequacy and effectiveness of the Authorised Person's governance, systems and controls for managing the risks arising from its DeFi engagement,

including whether those arrangements remain appropriate as the engagement, exposure or underlying risk environment changes.

- 2.7.4 Authorised Persons should recognise that they do not generally control protocol level safety mechanisms. Monitoring should therefore include the status of those mechanisms (where observable), the manner in which they are governed, and the Authorised Person's preparedness to act if those mechanisms are triggered, fail, or are used in a manner adverse to the Authorised Person's position.
- 2.7.5 Monitoring should not rely solely on periodic review. Threshold based alerts, escalation triggers, and clear ownership of monitoring outputs should be in place. Where the Authorised Person uses third party monitoring or analytics tools, the Authorised Person should understand the methodology, coverage and limitations of those tools, and should retain the ability to interpret their output rather than depend on raw alerts. Monitoring should be capable of identifying material changes in emerging DeFi infrastructure dependencies relevant to the engagement (see 3.11).
- 2.7.6 Where the Authorised Person uses automated or agentic tooling to execute or route DeFi transactions, it should place defined bounds on the discretion that such tooling may exercise. These should include, as relevant to the engagement, allowed venues, protocols and counterparties, prohibited intermediate tokens, position, exposure and slippage limits, and behavioural circuit breakers. The Authorised Person should be able to detect anomalous behaviour by the tooling and to pause, constrain or override its operation in a timely manner.
- 2.7.7 Sound recordkeeping and monitoring also support efficient and data led supervisory engagement. The Authorised Person should design its monitoring and recordkeeping arrangements with sufficient structure and data quality that relevant information can be retrieved and made available to the FSRA on request (see 2.8). This Guidance does not introduce a new or standalone reporting regime for DeFi engagement, and the FSRA's existing notification and reporting requirements continue to apply.
- 2.7.8 Output from monitoring should feed into the Authorised Person's risk assessment (see 2.5), management information (see 2.8) and incident escalation (see 2.10) arrangements.

2.8 RECORDKEEPING, AUDITABILITY AND MANAGEMENT INFORMATION

- 2.8.1 Records of DeFi engagement should be sufficient to support internal accountability, supervisory engagement, post-event reconstruction, financial crime obligations, and prudential and conduct reporting where applicable. Records should be accurate, complete, time stamped, retrievable, and retained for periods consistent with the Authorised Person's regulatory obligations.
- 2.8.2 Records should include, at a minimum:
 - a. transaction records covering the activities undertaken, the parties involved (to the extent identifiable), the venues or protocols used, the onchain identifiers of the transactions and the wallets or addresses involved, and the value, asset and timing of each transaction;

- b. counterparty, protocol and venue identifiers sufficient to allow the Authorised Person and the FSRA to identify the entities, protocols and venues to which the Authorised Person is exposed;
 - c. execution path information sufficient to reconstruct the Authorised Person's transaction including routing, intermediaries, smart contract calls and dependency components involved. The Authorised Person is not expected to duplicate the onchain execution tree within its own records, but should retain the onchain identifiers and maintain the internal capability to reconstruct the execution path reliably from those identifiers;
 - d. approval and decision records, including risk assessments, due diligence outputs, approvals of engagement, approvals of departures from policy, valuation decisions, and the associated rationales;
 - e. control breach and incident records, including the nature of the breach or incident, its detection, the actions taken, the parties involved, the resolution and any lessons learned;
 - f. reconciliation records covering wallet balances, protocol positions, collateral, locked positions, governance token holdings, and other relevant exposures; and
 - g. pre-execution context records, including the intended execution parameters and tolerances, the inputs on which the decision to transact was based (such as quotes, prices or routing options considered), the authorisations under which the transaction was initiated (whether by a person, a policy engine, or an automated process), and the risk and compliance checks applied before execution.
- 2.8.3 These data points are intended to support efficient and data led supervisory engagement, and the Authorised Person should be capable of producing them in a structured and readily retrievable form on reasonable supervisory request. This is a recordkeeping and supervisory access expectation and does not in itself create a standalone or machine-readable reporting obligation. Authorised Persons should also consider whether their recordkeeping arrangements are capable of supporting any applicable tax reporting obligations in respect of digital assets, including under the OECD Crypto-Asset Reporting Framework ("CARF"). Records should be structured to support routine supervisory information needs efficiently, with full reconstruction of execution paths reserved for forensic or targeted supervisory inquiry.
- 2.8.4 Valuation and accounting policy should address DeFi exposures that may be illiquid, locked, contingent, or otherwise difficult to value at fair value. These include liquidity provider positions in concentrated or volatile pools, locked positions subject to redemption periods or unbonding windows, governance tokens received as incentives, claims represented by receipt tokens, wrapped or bridged assets where the wrapping arrangement is itself a source of value risk, and rehypothecated collateral. The Authorised Person should document its valuation methodology, sources of price data, treatment under stress, and the conditions under which positions are written down or marked to a recovery scenario.

- 2.8.5 Management information should be tailored to the audience and the decision it supports. Senior management information should support oversight of the Authorised Person's overall DeFi engagement, material exposures, dependencies, control breaches and incidents. Operational management information should support day-to-day risk management, exception handling and control monitoring.
- 2.8.6 Authorised Persons should consider the prudential treatment of DeFi exposures. In particular, Authorised Persons should be able to demonstrate, on a per-exposure basis:
- a. the classification of the underlying asset and any wrapping, bridging, or tokenisation arrangement;
 - b. the risks arising from the infrastructure on which the exposure is held, transferred or settled, including permissionless ledger and smart contract risk; and
 - c. where the exposure references fiat, a commodity, security or other reserve asset, the redemption, stabilisation and reserve management arrangements supporting that reference.
- 2.8.7 The Authorised Person should determine the applicable treatment of each material DeFi exposure under PRU and any other applicable FSRA frameworks, and should apply a conservative treatment where the classification, valuation, control, or realisable liquidity of the exposure is uncertain. An Authorised Person should not assume that a DeFi related exposure, beyond its use as collateral for risk management purposes, is eligible as collateral for the purposes of reducing regulatory capital requirements merely because the relevant asset is an Accepted Virtual Asset ("AVA"), Accepted Fiat-Referenced Token ("AFRT"), Digital Security, or otherwise permitted for use in connection with a Regulated Activity. This Guidance does not modify the treatment of capital requirements or collateral under PRU.

2.9 RESOURCING, COMPETENCE AND ACCOUNTABILITY

- 2.9.1 DeFi engagement should be supported by adequate human, technical and operational resources, with clear individual accountability and arrangements that are not excessively dependent on any single individual or on informal knowledge that has not been recorded and made available to all.
- 2.9.2 Authorised Persons should ensure that:
- a. personnel involved in DeFi engagement, oversight and control functions possess the technical understanding needed to assess and respond to DeFi specific risks, including the design and behaviour of smart contracts, governance arrangements, dependencies, custody mechanisms and execution environments;
 - b. training arrangements are in place and refreshed periodically, extending beyond technical personnel to senior management, internal audit and control functions whose oversight depends on adequate understanding of DeFi operational realities;

- c. responsibilities for transaction initiation, review, approval, execution, monitoring, reconciliation, incident response and recordkeeping are clearly allocated and appropriately segregated;
 - d. adequate staffing and coverage arrangements are maintained during staff sickness, leave and outside regular business hours, including through documented procedures, cross-functional cover and contingency arrangements, so that key responsibilities do not depend excessively on any single individual;
 - e. reporting lines and governance arrangements support independent, effective and timely risk oversight, including independence of control functions from commercial or trading incentives associated with DeFi engagement;
 - f. third party advisers, service providers and tooling are subject to appropriate oversight, and do not negate the Authorised Person's accountability for the integrity of its DeFi engagement; and
 - g. where the Authorised Person uses automated or agentic code or tooling to execute or route DeFi transactions, specific individuals are accountable for the design, deployment, operation and ongoing oversight of that code or tooling, and that accountability is not negated by the involvement of third party developers or vendors.
- 2.9.3 Specific individuals should be accountable for the Authorised Person's DeFi engagement risk management arrangements, including the design of those arrangements, their operation and their ongoing adequacy. The Authorised Person should be able to identify those individuals, the scope of their responsibility, and the basis on which they hold that accountability.

2.10 INCIDENT ESCALATION AND REGULATORY ENGAGEMENT

- 2.10.1 Arrangements for the escalation, handling and communication of DeFi incidents should be defined in advance and tested. DeFi incidents may unfold at the speed of block production, may propagate through dependency chains within minutes, and may be observable onchain before the Authorised Person has internally detected them. The Authorised Person's arrangements should reflect these timeframes.
- 2.10.2 The Authorised Person should establish internal procedures for identifying, escalating, assessing and communicating potential incidents. Relevant incident types include, but are not limited:
- a. protocol exploits and smart contract failures;
 - b. governance attacks or contested governance changes;
 - c. failed or compromised oracles, bridges, sequencers or other dependencies;
 - d. abnormal transaction patterns or unauthorised activity in the Authorised Person's wallets or signing arrangements;

- e. control breaches;
 - f. depeg or redemption failures affecting Fiat-Referenced Token exposures; and
 - g. other events that may give rise to operational, financial crime, prudential or conduct concerns.
- 2.10.3 Escalation procedures should be capable of operating outside normal business hours, given the continuous nature of DeFi operations. Escalation thresholds should be calibrated so that material events reach senior management and relevant control functions in time to support meaningful response, rather than only after the event has resolved.
- 2.10.4 The Authorised Person should preserve the confidentiality of incident information and restrict its handling to authorised personnel with a clear operational, control or legal need to know.
- 2.10.5 The FSRA may request information from Authorised Persons in relation to their DeFi engagements in order to assess risks or investigate specific incidents or patterns of concern. Authorised Persons are expected to respond in a timely, accurate and complete manner. The FSRA may also require Authorised Persons to conduct targeted reviews of suspicious, unusual, or higher risk DeFi engagements within a specified period, and Authorised Persons should take appropriate remedial action following such review.
- 2.10.6 The FSRA may from time to time communicate supervisory observations, enforcement developments, or emerging concerns relevant to DeFi related incidents. Authorised Persons should consider such communications carefully and assess whether corresponding enhancements are required to their internal reporting, communication, incident handling or regulatory engagement practices.
- 2.10.7 Where the Authorised Person becomes aware of a material incident or pattern of concern in connection with its DeFi engagement, the Authorised Person should assess whether any notification obligations apply under the relevant FSRA Rulebooks, including GEN 3.5.18 where the incident constitutes a material Cyber Incident. An incident affecting a DeFi protocol or provider on which the Authorised Person relies may trigger those obligations.

SECTION 3: DEFI INFRASTRUCTURE RISKS

3.1 OVERVIEW

- 3.1.1 This Section describes, by way of illustration, the common infrastructure level risks that arise in connection with DeFi engagement. The risk types set out below are illustrative and non-exhaustive. They are intended to support the due diligence, risk assessment and monitoring expectations in Section 2, rather than to operate as a self-standing methodology for assessing or approving any protocol. These risks may persist across protocols and venues and give rise to losses, control breaches, financial crime exposure, conduct issues or prudential exposure even where the Authorised Person's chosen

activity is otherwise well controlled through its broader governance and risk management arrangements.

- 3.1.2 Some risks may be sufficiently acute, or incapable of being effectively mitigated, that the Authorised Person should not initiate the relevant DeFi engagement or should cease an existing engagement on discovering that.
- 3.1.3 Each risk family in this Section is described in three parts: the nature of the risk, how the risk arises in practice, and the FSRA's desired outcomes for the Authorised Person's management of the risk.

3.2 CUSTODY, CONTROL AND ASSET ACCESS

Nature of the risk

- 3.2.1 Control over assets used in DeFi engagement is exercised through cryptographic key management. The party able to generate a valid signature using a wallet's private key controls the assets held in that wallet. Control can transfer instantly and irreversibly upon a signed transaction. Custody risk in DeFi accordingly turns on the integrity of the Authorised Person's signing arrangements, the architecture of its wallets and accounts, and the safe handling of any permissions granted to protocols or third parties to act on those wallets.

How the risk arises in practice

- 3.2.2 This risk manifests in several common patterns, as set out below:
 - a. Compromise of private keys or seed phrases or theft of signing devices resulting in unauthorised access, whether arising from social engineering, malware, supply chain attacks, insider threats or operational errors. Private keys or seed phrases being compromised may become apparent immediately or remain dormant until the attacker chooses to act;
 - b. Inadequately segregated wallet architecture and access controls, including single signer arrangements, multi-signature arrangements without sufficiently independent signers, and hot wallets holding significantly more digital assets than their operational purpose requires, each of which elevates the loss potential of a single compromise;
 - c. Delegated permissions to smart contracts (for example, token approvals enabling a protocol to move assets from the Authorised Person's wallet) that grant broader access than the immediate transaction requires, that persist beyond the engagement that gave rise to them, or that are not observable to the Authorised Person in the ordinary course;
 - d. Inadequate asset recovery and continuity arrangements, including loss or destruction of keys, failure of wallet infrastructure during a transaction, or absence of tested recovery procedures; and

- e. Dependence on third party custody, wallet infrastructure or signing arrangements, where the Authorised Person remains exposed to the provider's operational resilience, security architecture, governance, financial soundness and incident response capability, and where limited visibility into provider systems may delay detection of failures.

Desired outcomes

3.2.3 These include the following:

- a. An Authorised Person knows where its assets used in DeFi engagement are held, on what basis they are controlled, what permissions have been delegated to which contracts or third parties, and how those permissions are reviewed and revoked;
- b. An Authorised Person's signing and access arrangements are commensurate with the value and operational profile of its DeFi engagement, with appropriate segregation of authority;
- c. An Authorised Person can detect a compromise of its signing arrangements in a timely manner and respond, including by revoking delegated permissions where it is able to do so; and
- d. An Authorised Person's reliance on third party wallet or signing services is supported by adequate due diligence, contractual rights, and the Authorised Person's residual capability to act if the provider becomes unavailable.

3.2.4 Authorised Persons should refer to:

- a. Chapter 15 and Chapter 16 of the Conduct of Business Rulebook ("COBS") for the FSRA's expectations on safe custody of Client Assets and reconciliations;
- b. Chapter 17 of COBS for Virtual Asset specific custody obligations; and
- c. Chapter 13 (Cryptography) and Chapter 15 (Decentralised Infrastructure Solutions), in particular Desired Outcome 13.2 (Key Lifecycle Management) and the Digital Wallet Security provisions at 15.2.14 to 15.2.18, of the ITRMG for the FSRA's expectations on cryptographic schemes, key lifecycle management and digital wallet security.

- 3.2.5 An Authorised Person should also refer to GEN Rule 3.5.1 and the applicable requirements concerning Third-Party Cyber Risk under the Cyber Risk Management Framework, including appropriate notification, remediation cooperation and assurance arrangements with relevant third-party service providers. Where the Authorised Person is a Recognised Body, it should also have regard to MIR 2.10 (Custody) and MIR 2.5 (Systems, controls and conflicts, including the safeguarding and administration of assets belonging to users of its facilities).

3.3 PRIVACY, TRACEABILITY AND FINANCIAL CRIME CONSTRAINTS

Nature of the risk

3.3.1 Most DeFi engagement occurs on public, pseudonymous distributed ledgers. Transaction histories are observable, but the natural or legal identities of the parties behind addresses are not. Different privacy designs exist within the ecosystem and they give rise to financial crime risk in different ways. For example:

- a. most public chains support full traceability of transactions and counterparties;
- b. some Virtual Assets and protocol arrangements offer optional privacy features that may or may not impede KYT screening, depending on configuration;
- c. some venues, including emerging compliant privacy designs, may permit holders to demonstrate clean status while masking identity to third parties; and
- d. certain designs, including shielded transactions and Virtual Assets that enforce non-traceability by default, are intended to defeat traceability altogether.

The financial crime profile of a given DeFi engagement therefore depends on the privacy design in question, and on the screening controls operated at both the venue and the Authorised Person.

How the risk arises in practice

3.3.2 This risk arises through patterns including:

- a. exposure to wallet addresses, smart contracts or protocols subject to applicable Sanctions, including those administered by the UAE (including the Local Terrorist List), the United Nations Security Council (the UNSC Consolidated List), the U.S. Office of Foreign Assets Control ("OFAC", including its Specially Designated Nationals and Blocked Persons list), and other relevant authorities, as defined in AML;
- b. exposure to tainted funds via deposits, swaps, lending pools or liquidity pools that have received or commingled assets from illicit sources;
- c. interaction with shielded transactions, mixing services, or protocols that enforce non-traceability by default, which defeat KYT screening and negate the prohibition on Privacy Tokens and digital assets employing similar technology;
- d. interaction with Virtual Assets or arrangements that incorporate optional privacy features, where the effect on KYT screening depends on configuration, and where the Authorised Person should assess whether effective monitoring remains possible in practice;

- e. reliance on screening controls operated by the venue or protocol itself (for example, pre-connection screening of wallet addresses against Sanctions Lists), the design and ongoing reliability of which may not be transparent to the Authorised Person;
- f. difficulty in applying customer due diligence and assessing transactional exposure where the interaction is with an address, a smart contract, or a pool rather than an identifiable person;
- g. sudden changes in the financial crime profile of a protocol, including the discovery that its deployer, administrator or controlling address has previously been associated with illicit activity; and
- h. sanctions exposure may be present at more than one layer: at the counterparty or wallet address level, at the protocol level (where the protocol or its developers become subject to Sanctions), and at the issuer level (where the asset issuer becomes subject to Sanctions). Each layer requires a separate assessment in the Authorised Person's risk-based approach.

Desired outcomes

3.3.3 These include the following:

- a. the Authorised Person has identified, assessed and documented the financial crime risks associated with each DeFi engagement, including Sanctions exposure;
- b. transaction monitoring systems and controls cover DeFi specific patterns, including pre-transaction screening of counterparties, intermediate addresses and recipient addresses, and post-execution review of transaction paths;
- c. the Authorised Person retains sufficient information about counterparties, intermediate addresses, and execution paths to demonstrate compliance with applicable AML obligations and to support timely supervisory engagement;
- d. where the engagement involves Virtual Assets or protocols that incorporate optional privacy features, the Authorised Person has assessed whether effective monitoring remains possible, has implemented controls to identify and restrict transactions made using such features, and treats inbound transfers using features consistent with the FSRA's expectations under the Guidance - Regulation of Virtual Asset Activities in ADGM;
- e. where the venue or protocol itself screens for sanctioned addresses or other compliance signals before permitting connection or transaction, the Authorised Person treats that screening as one input to its own controls and not as a substitute for them;
- f. the Authorised Person does not engage with assets that feature non-traceability by default, or with digital assets employing similar technology, consistent with the FSRA's prohibition under section 5A(4) of FSMR;

- g. the Authorised Person's financial crime controls address the way DeFi transactions are routed and executed, including screening of execution components such as pools, bridges, routers and aggregators, and review of actual execution paths against intended routing (see also 2.7);
- h. the Authorised Person maintains documented thresholds and escalation procedures for rejecting, pausing, exiting or otherwise restricting a DeFi engagement where financial crime risk exceeds its risk appetite, with timely information to the Money Laundering Reporting Officer and senior management.

3.3.4 Authorised Persons should refer to the:

- a. AML in full;
- b. COBS Rule 17.5(c) (Origin and destination of Virtual Asset funds) and COBS Rule 17.5(e) (Risk Management);
- c. Guidance for the Regulation of Virtual Asset Activities, in particular the Traceability and Monitoring assessment criterion; and
- d. FATF Recommendation 15 and the FATF Guidance for a Risk-Based Approach to Virtual Assets and Virtual Asset Service Providers.

Where the Authorised Person is a Recognised Body, it should also have regard to MIR 2.9 (Financial Crime and Market Abuse).

3.4 SMART CONTRACT

Nature of the risk

- 3.4.1 DeFi protocols are encoded in smart contracts that execute deterministically on the underlying blockchain. The contract's behaviour is its source of authority: the protocol does what the code dictates, regardless of the protocol's stated intentions. Vulnerabilities, design flaws, configuration errors, integration weaknesses, and upgrades that introduce new code paths may result in operational and financial loss for any Authorised Person whose engagement depends on the contract.

How the risk arises in practice

- 3.4.2 This risk manifests through patterns including:

- a. coding vulnerabilities, including re-entrancy, integer overflow or underflow, unchecked external calls, access control errors, inadequate input validation, gas related weaknesses, and incorrect storage initialisation;
- b. design and economic vulnerabilities, including arithmetic models that break under stress, incentive structures that can be exploited, flash-loan enabled manipulation or exploitation, and AMM invariants that are violated by particular instruments,

including instruments whose supply, fee or settlement mechanics depart from standard AMM assumptions;

- c. integration weaknesses, where contracts interact with other contracts under assumptions that are not satisfied in production, particularly across composable strategies;
- d. upgrade and fork risks, where upgrades introduce new code paths, where emergency upgrades bypass normal governance review, or where chain forks produce competing versions of the protocol's state;
- e. audit limitations, recognising that audits provide point-in-time assurance over a defined scope, may not identify novel attack vectors, and lose validity when the code changes;
- f. external call risk, where the contract's behaviour depends on calls to other contracts whose behaviour may itself be vulnerable; and
- g. interaction risk, where users (including the Authorised Person's personnel) approve transactions whose actual effect differs from the effect the front end interface represents.

Desired outcomes

3.4.3 These include the following:

- a. the Authorised Person understands the smart contract footprint of each protocol with which it engages, including upgrade authority and emergency powers (see also 3.5);
- b. the Authorised Person considers smart contract security history, including audit history, identified vulnerabilities, incident history and remediation, before initiating engagement and at intervals during the engagement as part of its ongoing monitoring;
- c. the Authorised Person has procedures for responding to newly discovered vulnerabilities affecting protocols on which it relies, including pausing engagement, withdrawing assets, or revoking delegated permissions where it is able to do so; and
- d. the Authorised Person's exposure size, hedging arrangements and stress test outputs reflect the residual smart contract risk that remains after due diligence.

3.4.4 Authorised Persons should refer to:

- a. GEN for the FSRA's expectations on technology governance;
- b. Guidance - Regulation of Virtual Asset Activities in ADGM (specifically the section on Technology Governance and Controls); and

- c. ITRMG, in particular the Programmable Contract Security provisions at 15.2.12 and 15.2.13, on secure development practices and on due diligence prior to transacting with programmable contracts created by third parties.

3.5 PROTOCOL GOVERNANCE

Nature of the risk

3.5.1 DeFi protocols typically operate under governance arrangements that determine who may change protocol parameters, who may upgrade smart contracts and who may exercise emergency powers. Governance may be exercised by token holders:

- a. through voting,
- b. by a foundation or development team,
- c. by a multi-signature group,
- d. by a designated administrator address or by some combination of these factors.

The Authorised Person's exposure is shaped not only by the protocol's current rules but by the credible threat of change to those rules.

How the risk arises in practice

3.5.2 This risk manifests through patterns including:

- a. concentration of governance power, where a small number of holders or addresses are able to determine outcomes unilaterally or in coordination;
- b. capture, where voting power is acquired or coordinated to advance interests adverse to broader users of the protocol;
- c. conflicts of interest, where parties who benefit from a governance decision also vote on that decision;
- d. abrupt or emergency change, where protocol upgrades, parameter changes, or pause and unpauses are taken under expedited governance procedures with limited notice or scrutiny;
- e. legal and accountability ambiguity, including lack of clarity about the persons or arrangements through which governance decisions are made, the authority or influence those persons or arrangements exercise, and the means available to challenge or obtain redress in respect of those decisions; and
- f. drift, where gradual change in governance composition or voting behaviour alters the protocol's risk profile.

Desired outcomes

3.5.3 These include the following:

- a. the Authorised Person has assessed the governance arrangements of each protocol on which it relies, including the location of administrative and upgrade authority, the conditions under which that may be exercised, any legal persons, foundations or similar arrangements involved in the protocol's governance and any material concentration of authority, control or influence over such;
- b. the Authorised Person monitors governance activity affecting protocols on which it relies, including proposal flow, voting outcomes, changes in administrative authority, and use of emergency powers;
- c. where the Authorised Person is itself a governance token holder, voting participant, or occupies another role in relation to the protocol, the Authorised Person addresses any potential or actual conflicts of interest arising from that participation, consistent with Section 2.2 and Section 2.4 of this Guidance; and
- d. the Authorised Person adjusts its exposure to a protocol in response to material adverse governance change.

3.5.4 Authorised Persons should refer to GEN for the FSRA's expectations on governance arrangements, conflicts of interest and senior management responsibilities, and to the Guidance - Regulation of Virtual Asset Activities in ADGM.

3.6 ORACLE AND EXTERNAL DATA DEPENDENCY

Nature of the risk

3.6.1 Many DeFi protocols depend on external data inputs, most commonly price feeds supplied by oracle services. The protocol's behaviour, including the valuation of collateral, the triggering of liquidations, the settlement of derivative positions and the release of escrowed funds, is conditioned on what the oracle reports. The integrity, freshness and resilience of those data inputs are therefore part of the protocol's risk surface.

How the risk arises in practice

3.6.2 These risks manifest through patterns including:

- a. manipulation of underlying price data, including through flash-loan enabled transactions, particularly where the oracle draws from low liquidity sources susceptible to short-term distortion;
- b. oracle failure or delay, in which the oracle reports stale data, fails to update through a period of market movement, or experiences technical interruption;

- c. oracle or data-feed misconfiguration, including inappropriate price bounds, deviation thresholds, update intervals or fallback parameters;
- d. single source or correlated source dependency, where a protocol relies on a single oracle provider or a small set of providers whose data sources are themselves correlated;
- e. taking advantage of oracle latency, where transactions are timed to exploit the gap between actual market movement and the oracle's updated value;
- f. cross-protocol contagion, where a failure in one oracle propagates to all protocols that rely on it; and
- g. dependence on external data feeds beyond pricing, including identity attestations, screening oracle outputs, off-chain proof inputs and similar inputs, where applicable to the engagement.

Desired outcomes

3.6.3 These include the following:

- a. the Authorised Person understands the oracle and external data dependencies of each protocol on which it relies, including the providers, the data sources, the update mechanism and the conditions under which the data feed could be disrupted;
- b. the Authorised Person has assessed the redundancy and failover behaviour of the oracle arrangements relevant to its engagement;
- c. the Authorised Person monitors the operational status of oracle feeds where observable, and is prepared to act where oracle data gives rise to adverse effects for the Authorised Person;
- d. stress testing addresses oracle manipulation and oracle failure scenarios, calibrated to the engagement's reliance on the affected data feed; and
- e. the Authorised Person has considered how it would respond if oracle manipulation or failure occurred, including the conditions under which protocol level recovery or governance driven remediation may or may not be available.

3.6.4 Authorised Persons should refer to Sections 2.5 (due diligence and risk assessment) and 2.7 (continuous monitoring and detection) of this Guidance.

3.7 BRIDGE AND INTEROPERABILITY

Nature of the risk

3.7.1 Cross-chain bridges and interoperability protocols enable assets and messages to move between distinct blockchain networks. They typically work by locking assets on one chain and minting representative tokens on another, or by relaying messages via validators or

proof systems that connect the two networks. Each bridge or interoperability protocol therefore introduces a layer of trust and a new failure surface that does not exist in either underlying chain.

How the risk arises in practice

3.7.2 This risk manifests through patterns including:

- a. smart contract vulnerabilities within the bridge itself, which have historically given rise to some of the largest losses in DeFi;
- b. validator set compromise or collusion, in bridges that rely on a federated set of attestors;
- c. message relay failure or manipulation, including where changes in an underlying chain result in the source and destination chains recording inconsistent outcomes;
- d. asset recovery uncertainty when a bridge fails, where the representative token may become unredeemable or its one-for-one backing may not be reconstitutable;
- e. cascading exposure, where multiple protocols rely on the same bridge or wrapped asset; and
- f. persistent operator dependency, where bridged or wrapped assets remain exposed to the compromise or non-performance of the bridge operator notwithstanding the appearance of holding the underlying asset.

Desired outcomes

3.7.3 These include the following:

- a. the Authorised Person identifies the bridges, wrapping arrangements and interoperability protocols on which its engagement depends, including indirect dependencies;
- b. the Authorised Person understands the trust assumptions of each such arrangement, including the persons or mechanisms that attest to cross-chain messages, the conditions under which those attestations are made or accepted, and the available means of redress;
- c. the Authorised Person treats wrapped or bridged assets distinctly from the underlying asset for purposes of due diligence, monitoring, valuation and recovery planning (see also 2.5 and 2.8);
- d. stress testing addresses bridge failure scenarios, including loss of redemption and partial loss outcomes; and
- e. where the Authorised Person engages with cross-chain or interoperable arrangements involving multiple asset standards or settlement assets, it has

considered the consistency of token standards used at each leg of execution, the quality and regulatory standing of the settlement asset used at each step, and whether the interoperability arrangement preserves the legal and operational properties of the underlying instrument.

- 3.7.4 Authorised Persons should refer to Sections 2.4 (due diligence and risk assessment), 2.5 (third party dependencies and concentration awareness) and 3.7 (dependency chain and composability risk) of this Guidance.

3.8 DEPENDENCY CHAIN AND COMPOSABILITY

Nature of the risk

- 3.8.1 DeFi protocols are designed to be composable. A position in one protocol may be used as collateral in another, the resulting position may be supplied to a third, and so on. The Authorised Person's effective exposure therefore extends beyond the protocols with which it directly engages to include every protocol in the composition path. A failure at any node in the path can propagate to all positions that depend on it.

How the risk arises in practice

- 3.8.2 This risk manifests through patterns including:

- a. risk transmission through composability paths, where an exploit, governance event, or oracle failure at one protocol triggers losses at protocols downstream;
- b. hidden dependencies, where the Authorised Person's chosen protocol relies in turn on infrastructure the Authorised Person has not assessed, including shared toolchain or library dependencies (such as compilers and code frameworks) whose vulnerabilities can cascade simultaneously across all protocols built on them;
- c. layered exposure, where a single underlying asset supports multiple layered positions that are individually small but collectively significant; and
- d. cross-protocol contagion, where stress at one protocol triggers liquidations or withdrawals at others that share liquidity, oracle or governance dependencies.

- 3.8.3 Authorised Persons should take into account the compounding nature of risk across interconnected DeFi protocols. Assessing a single protocol in isolation is insufficient, as the overall security of a transaction is determined by its most fragile underlying dependency. The assessment of dependency chain and composability risks should therefore be continuous as protocol architectures and governance arrangements change frequently.

Desired outcomes

3.8.4 These include the following:

- a. the Authorised Person maps the material composability path of each material DeFi engagement, identifying the protocols and dependencies on which the engagement is conditional;
- b. the Authorised Person assesses the most fragile material dependency in the path and reflects that dependency in the risk profile of the engagement;
- c. the Authorised Person monitors material changes affecting important nodes in the path, including upgrades, governance events, dependency changes and incidents; and
- d. stress testing addresses contagion scenarios, including the cascading effect of a single node failure on the Authorised Person's broader DeFi exposure.

3.8.5 Authorised Persons should refer to Sections 3.6 (oracle), 3.7 (bridges), 2.5 (risk assessment) and 2.6 (third party dependencies) of this Guidance.

3.9 EXECUTION ENVIRONMENT AND TRANSACTION FINALITY

Nature of the risk

3.9.1 DeFi transactions execute within the operating rules of the underlying blockchain. Those rules govern how transactions are ordered, when they are considered final, and what conditions may cause them to be reversed or re-organised. Different chains and rollups apply different rules. Authorised Persons should understand the execution environment behaviours of the chains on which they transact, because those behaviours affect whether the Authorised Person's transactions execute as intended and whether they can be relied upon thereafter.

How the risk arises in practice

3.9.2 This risk manifests through patterns including:

- a. maximal extractable value ("MEV") exposure, where third parties able to influence transaction ordering capture value at the expense of the Authorised Person, including through sandwich attacks, front running and order flow extraction;
- b. sequencer or block proposer power, particularly where a centralised or concentrated set of participants may delay, censor, reorder or otherwise affect the inclusion or finality of transactions;
- c. re-organisation and finality dynamics, where transactions deemed accepted may be reversed if the underlying chain experiences a re-organisation, with consequences for the validity of dependent state;

- d. mempool visibility, where pending transactions are publicly observable before execution, exposing the Authorised Person's intended actions to other parties;
- e. front end and execution tooling integrity, where the dashboard, wallet interface or other tooling used to compose and submit transactions does not represent what the Authorised Person believes it is doing; and
- f. atomic settlement dependence, where a multi-leg transaction is designed to settle as a single, indivisible unit and where the legs depend on each other to such an extent that a failure or revert in one leg invalidates the entire transaction; the Authorised Person should understand the atomicity properties of the arrangements it uses and the conditions under which partial completion is, or is not, possible.

Desired outcomes

3.9.3 These include the following:

- a. the Authorised Person understands the execution environment characteristics of the chains and rollups on which it transacts, including ordering rules, finality assumptions and the parties able to influence them;
- b. the Authorised Person has assessed its exposure to MEV and has determined appropriate mitigations for its engagement, including private relay submission, slippage tolerance, transaction sizing, batched execution or other measures;
- c. the Authorised Person treats transactions as final only at the point appropriate to the underlying chain's finality model;
- d. the Authorised Person can detect adverse changes in the execution environment, including sequencer downtime, censorship or re-organisation incidents; and
- e. where the Authorised Person relies on intent based execution, solver networks, relayers, routers or auctions to submit or execute transactions, it assesses how those arrangements affect transaction ordering, execution certainty, route selection, conflicts of interest, information leakage, failed execution and fallback arrangements (see also 3.11).

3.9.4 Authorised Persons should refer to Sections 2.5 (due diligence and risk assessment) and 2.7 (continuous monitoring and detection) of this Guidance.

3.10 MECHANISM DESIGN AND SCALING FRAGILITY

Nature of the risk

3.10.1 DeFi protocols implement mechanisms (including auction structures, AMM invariant breakdowns, lending interest curves, liquidation cascades, redemption arrangements and fee structures) that work as intended within their design envelope and may behave unexpectedly outside it. Scaling, including growth in volume, growth in collateral, growth in concentration, or growth in interconnection, can move a protocol from its intended

envelope into a regime in which its mechanisms produce results the designers did not anticipate.

How the risk arises in practice

3.10.2 This risk manifests through patterns including:

- a. liquidation cascades, in which falling collateral values trigger liquidations that themselves accelerate the fall;
- b. feedback loops within incentive structures, where the pursuit of incentive rewards distorts the underlying activity in ways that compromise stability;
- c. AMM invariant breakdowns, including under conditions of extreme volatility, low liquidity, or interaction with instruments whose mechanics violate standard AMM assumptions, such as rebasing, elastic supply, or fee on transfer tokens;
- d. bank run dynamics in pooled liquidity protocols, where rapid or concentrated withdrawals may create liquidity stress and, under adverse conditions, contribute to forced liquidations, impaired redemptions or losses for remaining participants;
- e. scaling stresses on dependency providers, where growth in protocol size strains the oracles, bridges or settlement infrastructure on which it depends; and
- f. reflexivity in valuations, where mark-to-market or oracle supplied prices interact with positions in ways that amplify market movements.

Desired outcomes

3.10.3 These include the following:

- a. the Authorised Person understands the mechanism design of each protocol on which it relies, and the conditions under which that design may not behave as intended;
- b. stress testing covers mechanism design failure modes, including liquidation cascades, feedback loops, AMM invariant breakdowns and reflexivity in valuation;
- c. the Authorised Person has determined the conditions under which it would scale back or unwind its engagement; and
- d. exposure size is calibrated to the design tolerances of the protocols on which the Authorised Person relies, and not to their idealised operating envelope.

3.10.4 Authorised Persons should refer to Sections 2.5 (due diligence and risk assessment) and 2.7 (continuous monitoring and detection) of this Guidance.

3.11 EMERGING AND FORWARD-LOOKING DEFI INFRASTRUCTURE RISKS

Nature of the risk

3.11.1 DeFi infrastructure, execution models, automation and cryptographic standards continue to change. New forms of transaction routing, automated decision making, wallet design, middleware and cryptographic security may alter in future how an Authorised Person's transactions are initiated, routed, approved, monitored, settled or controlled, and may give rise to operational, financial crime, conduct, market integrity, prudential or resilience risk even where the underlying activity is already subject to existing controls. Consistent with the technology neutral approach of this Guidance, the developments noted below are illustrative; the FSRA's expectation is that the Authorised Person maintains a process for identifying and assessing emerging infrastructure risk that is material to its DeFi engagement, having regard to the criticality of dependencies, automation, cryptographic assumptions and control surface involved.

How the risk arises in practice

3.11.2 Emerging infrastructure risk may arise where:

- a. the economic outcome of a transaction depends on third party solvers, routers, auctions or relayers whose incentives, reliability or failure modes are not transparent to the Authorised Person;
- b. models, agents or automated systems influence execution, liquidation, collateral management, pricing, risk monitoring or governance participation;
- c. cryptographic schemes, signatures, wallets or dependent contracts may weaken as standards evolve or quantum computing capability matures; and
- d. emerging technical standards, wallet models, proof systems or interoperability arrangements create new third party, concentration or operational resilience dependencies.

Desired outcomes

3.11.3 These include the following:

- a. the Authorised Person has a documented and proportionate process for identifying, assessing, approving, monitoring and escalating emerging DeFi infrastructure risk relevant to its engagement;
- b. the Authorised Person assesses material changes in execution design, automation, cryptographic assumptions, wallet infrastructure or third-party dependencies before relying on them in connection with a Regulated Activity, and does not rely on mechanisms it does not understand;

- c. where intent based execution, solver networks, or automated or agentic systems are used, the Authorised Person applies appropriate governance, oversight, conflicts of interest management, human override and incident escalation controls, and assesses whether the resulting execution is consistent with its obligations to Clients (see also 3.9); and
- d. where cryptographic transition risk is material to its engagement, the Authorised Person maintains a proportionate plan for monitoring developments in cryptographic standards and in the readiness of relevant vendors, protocols, wallets and contract dependencies, and for managing migration over time where migration becomes necessary and feasible.

SECTION 4: DEFI EXPOSURE RISKS

4.1 OVERVIEW

- 4.1.1 This Section describes the common risks that arise from the types of instruments and exposure structures an Authorised Person may encounter in connection with its DeFi engagement. The exposure types set out below are illustrative and non-exhaustive. They are intended to support the due diligence, risk assessment and monitoring expectations in Section 2, rather than to classify any instrument or to settle its treatment under an FSRA framework. The focus is on the nature of the claim or entitlement, the dependencies supporting it, any re-use or layering of assets, and the channels through which redemption constraints, failures or failures may transmit. Where an instrument or exposure is already addressed under existing FSRA frameworks, including those for Virtual Assets, Fiat-Referenced Tokens ("FRTs"), Digital Securities, staking, derivatives or Listing Authority matters, Authorised Persons should consider this Guidance alongside those frameworks.
- 4.1.2 Authorised Persons must not engage in DeFi activities using assets whose use is prohibited under the FSRA framework. Where the FSRA framework requires the use of an asset to be permitted by the FSRA, including an AVA or AFRT, the Authorised Person should ensure that the appropriate permission requirement is satisfied. Digital Securities and other tokenised assets may only be used where their use is permitted under the applicable FSRA requirements and the relevant Regulated Activity. The treatment of an asset under the FSRA framework is not changed by it being wrapped, tokenised, bridged or used within a DeFi protocol, and such use does not of itself create any permission or alter the applicable regulatory treatment.
- 4.1.3 Authorised Persons should also be alert to instruments whose supply, fee or settlement mechanics depart from the assumptions on which standard AMM arrangements rely. These include rebasing tokens, elastic supply tokens, fee on transfer tokens, and tokens whose state is updated programmatically rather than by transfer. Such mechanics may disrupt AMM arithmetic and introduce smart contract complications when the instruments are layered into DeFi protocols, even where the underlying instrument is not itself the focus of this Guidance.

4.2 FIAT-REFERENCED TOKEN EXPOSURES

Nature of the risk

- 4.2.1 FRTs are designed to maintain a stable value against a reference fiat reference. They are used across DeFi as a unit of account, a settlement medium, a collateral asset, and as a building block for synthetic structures. Their suitability for those uses depends on the credibility of the peg, the reliability of the issuer's redemption arrangements, and the legal nature of the token holder's claim against the issuer.

How the risk arises in practice

- 4.2.2 FRT exposure in DeFi includes:

- a. peg loss events, in which the market price of an FRT departs from its reference value, with consequences for any DeFi position denominated in or collateralised by the token;
- b. redemption arrangement failure, in which the issuer is unable or unwilling to redeem the token at par;
- c. issuer level failure, in which a legal claim against the issuer's reserves becomes uncertain or contested;
- d. issuer control actions, including the freezing or blacklisting of tokens or addresses, which may restrict transfer, redemption, liquidation or exit from a DeFi position;
- e. contagion across protocols that hold or accept an affected FRT, including those that depend on that FRT as a price oracle reference or as a routing currency; and
- f. regime risk, in which the regulatory standing of an FRT changes during the period of the Authorised Person's engagement.

Desired outcomes

- 4.2.3 These include the following:

- a. the Authorised Person understands the nature of its exposure to an FRT through DeFi, including the relevant peg, redemption, liquidity and contagion risks, without treating the FSRA's acceptance of the FRT as removing the need to assess those engagement-specific risks; and
- b. the Authorised Person considers the contagion channels through which an FRT event would affect its other, broader DeFi positions.

- 4.2.4 Authorised Persons should refer to Chapter 17 of COBS, to the Guidance - Regulation of Virtual Asset Activities in ADGM, and to the FSRA's framework for FRTs. Where an Authorised Person uses an FRT in undertaking Regulated Activities, the Authorised Person should ensure it is an AFRT in accordance with the applicable FSRA requirements.

The Authorised Person must not assume that a wrapped, bridged or other tokenised representation of an AFRT is itself an AFRT or has the same regulatory treatment. Algorithmic Stablecoins are prohibited for use in carrying on any Regulated Activity in ADGM.

4.3 SYNTHETIC ASSET AND DERIVATIVE-LIKE EXPOSURES

Nature of the risk

- 4.3.1 Synthetic exposures replicate the payoff of an underlying instrument without holding the underlying itself, typically through smart contracts that track price, settle in collateral, and apply rules for liquidation. The reliability of the exposure depends on the integrity of the price source, the sufficiency of collateral, and the operation of the settlement and liquidation mechanism.
- 4.3.2 The term “derivative-like” describes economic and risk characteristics only and does not determine whether an exposure is a Derivative, another type of Specified Investment or a Security under the FSRA framework.

How the risk arises in practice

- 4.3.3 Synthetic and derivative-like exposure characteristics include:
- a. oracle dependence, with consequences as described in Section 3.6;
 - b. collateralisation arrangements that may be over-collateralised, under-collateralised or algorithmically adjusted, and that may fail to provide the expected protection under stress;
 - c. liquidation dynamics that may produce sudden, cascading or partial outcomes, particularly under conditions of thin liquidity;
 - d. settlement pathways that may involve a separate token, a redemption against the protocol, or a claim against a pool of users; and
 - e. payoff structures that diverge from those of comparable traditional derivatives, including the consequences of perpetual funding rate mechanisms.

Desired outcomes

- 4.3.4 These include the following:
- a. the Authorised Person understands the precise nature of the claim or payoff represented by each synthetic exposure;
 - b. the Authorised Person treats the synthetic exposure as a distinct instrument from the underlying for purposes of due diligence, monitoring, valuation and risk control;

- c. stress testing captures the synthetic exposure's specific failure modes, including liquidation cascades, oracle failure and collateral inadequacy; and
- d. the Authorised Person considers whether the synthetic exposure is, or may be, a Derivative, another type of Specified Investment or otherwise within an existing FSRA regulatory category, and refers to the applicable framework accordingly.

4.3.5 Authorised Persons should refer to the FSRA's frameworks for Derivatives and for Digital Securities where classification or perimeter questions arise.

4.4 RECEIPT TOKEN AND TOKENISED CLAIM EXPOSURES

Nature of the risk

4.4.1 A receipt token represents a claim against a position held within a protocol, a custodian, or a trustee or agent arrangement. The token is the holder's instrument of recourse whereas the position the token represents is the holder's economic interest: it is important to note that the two are conceptually distinct and may diverge in value and/or in legal effect.

How the risk arises in practice

4.4.2 Receipt token and tokenised claim exposures arise in patterns including:

- a. staking derivative tokens that represent staked assets and their associated rewards;
- b. liquidity provider tokens that represent a share of a pool's underlying assets and accrued fees;
- c. lending protocol receipt tokens that represent a deposit and accrued interest;
- d. structured product or vault tokens that represent claims against a strategy or pooled vehicle;
- e. tokenised claims against off-chain assets, including custody receipts and tokenised representations of regulated underlyings; and
- f. fractionalised tokens, where a single underlying position or asset is represented by a number of fungible fractionalised tokens issued onchain, with the consequence that the holder's claim is a proportionate interest reconstituted across multiple fraction bearers and that exit, redemption and recovery may depend on the proportion of fractions the Authorised Person holds and on the issuer's arrangements for reconstituting the whole.

4.4.3 The risks associated with each receipt token exposure include:

- a. the redemption pathway, including the conditions under which the token may be exchanged for the underlying position and the time required;

- b. the integrity of the issuing protocol, custodian or trustee or agent infrastructure;
- c. the legal nature of the holder's claim, particularly whether the holder has a direct interest in the underlying assets or only a contractual claim against the issuer;
- d. the transferability and composability of the token, including its use as collateral in other protocols, which may involve additional dependencies; and
- e. the treatment of the underlying position if the receipt token is lost, destroyed or compromised.

Desired outcomes

4.4.4 These include the following:

- a. the Authorised Person understands, for each receipt token exposure, the underlying position, the redemption pathway, and the legal nature of the holder's claim;
- b. the Authorised Person considers whether the receipt token may itself fall within an existing category, including as a Specified Investment, a Digital Security, or a Virtual Asset, and refers to the applicable FSRA framework accordingly;
- c. the Authorised Person treats the receipt token as a distinct instrument from the underlying for valuation, risk control, and recordkeeping purposes; and
- d. the Authorised Person considers the implications of using receipt tokens as collateral or input to other DeFi engagements, given the additional layering of dependencies that this introduces.

4.4.5 Authorised Persons should refer to the FSRA's frameworks for Digital Securities, Virtual Assets and staking where the receipt token represents a position within those frameworks.

4.5 WRAPPED, BRIDGED AND CROSS-CHAIN ASSET EXPOSURES

Nature of the risk

4.5.1 A wrapped or bridged asset is a token issued on one blockchain that represents a holding of a different asset, typically held on another chain or under the control of a custodian or bridge operator. The token derives its value from the underlying asset and from the credibility of the wrapping or bridging arrangement.

How the risk arises in practice

4.5.2 Wrapped, bridged and cross-chain exposures arise in patterns including:

- a. chain-of-custody risk, including the integrity of the locking, minting, burning and unlocking arrangements;

- b. trust assumptions of the bridge or wrapping arrangement, including the persons or mechanisms that attest to cross-chain messages and the conditions under which attestations are valid;
- c. recovery pathways in the event of bridge or wrapping infrastructure failure, including whether the underlying asset can be reclaimed and on what basis;
- d. market price divergence between the wrapped token and the underlying, particularly during periods of stress or doubt about the wrapping arrangement; and
- e. cascading exposure where multiple protocols rely on the same wrapped or bridged asset.

Desired outcomes

4.5.3 These include the following:

- a. the Authorised Person treats each wrapped or bridged asset as a distinct exposure from the underlying for purposes of due diligence, valuation, monitoring and recovery planning;
- b. the Authorised Person understands the chain of custody and trust assumptions on which the wrapping or bridging arrangement relies, including the persons or mechanisms exercising material control and the conditions under which that control may be exercised;
- c. the Authorised Person considers how its engagement would be affected by failure of the wrapping or bridging arrangement, including loss of redemption or partial loss; and
- d. the Authorised Person refers to Section 3.7 of this Guidance for the infrastructure level treatment of bridge and interoperability risk.